

3. It is possible to open a URL without adding it to the history list. By using `location.replace`, we can open different URLs, one after the other, replacing the current history position.
4. SOP only prevents JavaScript from accessing URLs in the history; it does not prevent access to `history.length` (the number of elements in the global history list). Also, it is possible to load a specific URL from the history list, using `history.go(URL)`.

The following are XSHM attack vectors that use manipulation of the browser's history object:

- Cross-site condition leakage
- Cross-site user tracking
- Cross-site URL/parameters enumeration

We will focus on these, one by one.

Cross-site condition leakage

Let's suppose a site contains the following logic:

```
Page A: If(Condition)
      Redirect(Page B)
```

Here, an attacker can execute a CSRF attack to get an indication about the value of Condition (whether it's *TRUE* or *FALSE*) as feedback. Such an attack is executed from the

attacker's site, using the following attack process:

1. The attacker creates an *IFRAME* whose src is Page B.
2. The code saves the current value of `history.length` in a variable.
3. The code then changes the src of the *IFRAME* to Page A.
4. Upon comparing the saved value with the present value of `history.length`, if it is the same, then Condition is *TRUE*.

The above algorithm is based on the browser's history object displaying the behaviour listed as the second property/feature above. Consequently, `history.length` will remain the same after opening Page A, and this indicates that Condition is *TRUE*. If Condition was *FALSE*, then Page A being added to the browser's history would increase its length by one. Since attackers can open both URLs from their page inside an *IFRAME*, and `history.length` is accessible from a page on the attackers' site, this is a case of cross-site condition leakage—and hence, a violation of SOP. After getting an indication of the value of Condition, the attackers can now plan a two-way CSRF attack (a two-way CSRF attack means that the attackers will be getting a response for the CSRF attack). Let's have a look at a simple attack scenario.

Attack scenario

Let's suppose a bank application allows the transfer of money from one account to another. Now, the site might use the following code for this:

Go Online to learn Linux Device Drivers



Core skills like kernel programming or Linux device drivers should be learned at a slow and steady pace for fully comprehending it, says Mr. Raghu Bharadwaj, a lead trainer on core Linux programming. Unlike normal application software learning where it is mostly restricted to functionality based learning, system programming involves deep understanding and analysis of issues like the Linux kernel and its subsystems. Your options to learn these skills are classroom based training, learning through experience, self learning through trial and error and through an effective online course.

While all other modes of training has its own merits and demerits, online learning is definitely a step ahead, especially for courses like this. Online courses gives you the comfort of accessing it 24x7 and lets you learn things during hours of focus and interest. Another important aspect is that it permits you to go through each session any number of times and fully understand each and every topic effectively.

Mr. Raghu Bharadwaj is a lead trainer at Veda Solutions, you can listen to his training videos on Linux kernel and device drivers at www.techveda.org

First Online Course on Linux Device Drivers in India
www.techveda.org



RHCE | RHCSS

 **CCNA**

 **SOLARIS**

 **ORACLE**

DBA

*conditions Apply

Register for **RHCE**
& get **Rh423 Free***

Pioneers in LINUX Training

- Certified Faculties
- Corporate Clients
- DELL, NRS, GENPACT ETC.,
- Instructor Led Training
- 1:1 Systems/ Routers
- Weekend Batches
- Placement Assistance

New batches
6, 13, 20, 27 Dec 2010



Amrita Technologies
844/1, Shantiniketan Colony, Mahindra Hills,
East Marredpally, Secunderabad-26.

Tel: 9393733174 | 27733174 | 27737969
Email: aict.hybd@amrita.ac.in | www.amritahyd.org

